IT Security Incident Reporting Policy

Effective Date:
September 28, 2026

Category:
Security

Scheduled Review:
September 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This document replaces, in its entirety, the *IT Security Incident Reporting Policy*, dated January 6, 2025.

3. Purpose

This Information Technology Policy (ITP) establishes the requirements for the reporting of Cyber Security Incidents to ensure timely response, regulatory compliance, and effective risk mitigation across the Commonwealth.

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

5.1 General Requirements

Agencies shall comply with the Pennsylvania *Breach of Personal Information Notification Act, as amended June 28, 2024, P.L. 427, No. 33, 73 P.S. §§ 2301–2330,* including all requirements related to the identification, reporting, and notification of unauthorized access to unencrypted or unredacted personal information.

All Cyber Security Incidents shall be classified and reported in accordance with this policy and the *Security Incident Categorization, Alerting, and Reporting Standard*.

5.2 End User Incident Reporting

5.2.1 Reporting Methods

Commonwealth end users who suspect a Cyber Security Incident shall promptly report the suspected incident through one or more of the following channels:

1. **Phishing and Social Engineering:** Suspected phishing or social engineering emails shall be reported using the "Report Phishing" button in Outlook.

2. **General Security Incidents:** Other suspected security incidents, including but not limited to malware symptoms, disabled or malfunctioning security software, and potential data leakage, shall be reported via email to: OA-securityIncidents@pa.gov.

3. **Serious or Urgent Incidents:** Incidents involving actual or suspected compromise of Commonwealth systems or data, including ransomware or other cyber-attacks, shall be reported immediately by contacting the Cybersecurity Incident Hotline at 877-552-7478.

5.2.2 Required Information

When contacting the Cybersecurity Team, end users should provide as much of the following information as is known at the time of reporting:

- **Description**: A brief explanation of what occurred.
- **Timeline**: The date and time the incident was first noticed.
- **Impact**: Identification of affected systems, devices, or data, if known.

5.2.2 End User Responsibilities During a Security Incident

During a suspected or confirmed Cyber Security Incident, end users shall immediately cease all work on the suspected affected device and await further direction from the Cybersecurity Team**.** Additionally, end users **shall not**:

- Attempt to investigate, remediate, or otherwise resolve the incident independently.
- Power off the affected device unless explicitly instructed.
- Disconnect the affected device from the network (including unplugging ethernet cables or disabling Wi-Fi) unless specifically instructed.

5.3 Agency Incident Reporting

Agencies shall categorize, alert, and report Cyber Security Incidents in accordance with the *Security Incident Categorization, Alerting, and Reporting Standard*, including compliance with all incident classification criteria and mandatory alerting and reporting timelines.

5.4 Third-Party Incident Reporting

Third parties, vendors, contractors, and service organizations that store, process, transmit, or have access to Commonwealth data or systems must promptly report any suspected or confirmed Cyber Security Incident that may impact the confidentiality, integrity, or availability of Commonwealth data or services.

Cyber Security Incidents must be reported as soon as possible and no later than 24 hours after

discovery, unless a different reporting timeframe is required or permitted by contract, in which case the contractual reporting timeframe shall take precedence.

Third parties shall cooperate fully with Commonwealth incident response activities, including evidence preservation, forensic analysis, and remediation.

Third parties shall not notify external parties, including affected individuals, regulators, or the media, without written authorization from the Commonwealth.

5.5 Information Sharing with External Partners

Information specific to a Cyber Security Incident, including but not limited to Indicators of Compromise (IOCs), may not be shared with any external partners until remediation of the incident has been completed, unless such sharing is authorized by the Commonwealth Chief Information Security Officer (CISO) or the applicable agency Information Security Officer (ISO).

5.6 Incident Response

The Office of Administration, Office for Information Technology, Enterprise Information Security Office is responsible for coordinating and leading Cyber Security Incident response activities when an incident affects the enterprise, one or more agencies, or third parties with access to Commonwealth systems or data.

All Cyber Security Incidents must be responded to, contained, remediated, and closed in accordance with the Incident Response Process Document:

- Incident Response Process Document (Redacted Version) – Individual contact information has been removed. This version is available to Commonwealth personnel only.

- Incident Response Process Document (Unredacted Version) – Includes incident response contact information and is restricted to authorized personnel. Requests for access shall be submitted to the OA, IT Policy.

5.7 Incident Preparedness

Agencies shall develop and execute an annual tabletop exercise of the agency's Cyber Security Incident reporting and response processes.

Agencies shall ensure personnel with incident response responsibilities receive appropriate training and participate in the annual tabletop exercises.

5.8 Roles and Responsibilities

Roles and responsibilities for Cyber Security Incident reporting, including reporting, escalation, and notification requirements, are defined in the IT Security Incident Categorization, Alerting, and Reporting Standard.

6. Contact

Questions or comments may be directed via email to OA, IT Policy.

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document
Revision	04/10/2026	The policy was re-written The re-written policy focuses exclusively on cyber security incident reporting requirements and defers all incident response, remediation, and recovery activities to the Incident Response Process (IRP). Incident categorization criteria and alerting and reporting timelines were removed from the policy and established in a separate standards document. Added sections regarding third-party incident reporting and incident preparedness
Revision	09/28/2026	Updated links to the IRP document.